book *The Age of Surveillance Capitalism*, by Shoshana Zuboff (PublicAffairs, 2019).

But all is not lost. Let's return to our banking example to see why. The bank does keep logs of what you do and may show them to the proper authorities when required by regulation. But the record of what you do at the bank should not be available to outsiders or even employees of the bank without the need to know. Your interactions with the bank are functionally private—even though you may not have communications privacy, you do have information privacy, subject to the agreements the bank has with you.

2.7.3 Functional privacy

Functional privacy operationalizes information privacy by ensuring that systems access and process only the necessary information—nothing more. Functional privacy depends on both governance and technology to achieve its goals. Governance establishes the rules about who can access data and under what conditions. For example, the bank may create a rule that customer transactions are limited to employees with a need-to-know, which would form the basis for authorization policies. Governance is an important foundation for dynamic authorization. We'll cover it in detail in chapter 14.

Policy-Based Access Control (PBAC) is a good technology choice for enforcing these rules. Here's why:

- PBAC allows fine-grained access to different data and systems to be limited to only certain people, roles, or situations. For example, a financial analyst at a hospital may be allowed to confirm a patient's insurance coverage without being able to see their health history.
- By decoupling authorization from underlying systems, PBAC allows policies to be managed holistically, tested, and reviewed for correctness. Many business leaders may be comfortable reading policies to confirm they conform to rules written in English.
- PBAC allows many decisions to be made without having to expose sensitive information to human operators and reviewers. For example, a PBAC system could automatically enforce transaction size thresholds, sending only transactions over certain amounts to a human reviewer.